

Model Access Controls

1. What Model Access Controls Actually Enforce

Model access controls are the policy-and-enforcement layer that governs which identities — human users, service accounts, or autonomous agents — may invoke a given AI model, under what conditions, and with what usage limits. Unlike traditional application access control, model access must account for two AI-specific risks: the model itself can be a source of sensitive information (training data, embedded weights, fine-tuning corpora), and unrestricted inference can be weaponised for data exfiltration, denial of service, or adversarial probing. Effective model access controls therefore combine identity verification, authorisation policies, usage quotas, and audit logging into a unified governance layer.

The principle of least-privilege applies directly: a junior security analyst who needs to query a malware classification model does not need access to the organisation's crown-jewel threat-intelligence prediction model. Granting only what is necessary reduces the blast radius of any credential compromise and limits the surface area available to insider threats.

2. Classification and Sensitivity Tiers

Before you can enforce access, you need a consistent model inventory with sensitivity labels. A four-tier scheme maps well to most enterprise environments.

Tier	Label	Who Can Access	Typical AI Models
1	Public	Any authenticated user	Open-source malware scanners, public threat-feed summarisers
2	Internal	All employees on corporate network	Internal log-analysis assistants, helpdesk chatbots
3	Restricted	Named teams or roles (e.g. Threat Intel)	Behavioural anomaly detectors, vulnerability prioritisers
4	Confidential	Senior staff + explicit approval	Zero-day prediction models, strategic intelligence aggregators

Labels should be stored in a central model registry and referenced by all enforcement points — API gateways, inference servers, and CI/CD pipelines — so classification decisions propagate consistently without manual duplication.

3. Role-Based Access Control (RBAC) for AI Models

RBAC assigns permissions to roles rather than individuals, then maps users to roles. In an AI context the roles are defined by the job functions that legitimately need model access:

- Security Analyst — may invoke Tiers 1 and 2 models; read-only queries; no access to raw training data.

- Threat Intelligence Specialist — may invoke Tier 3 models; may export inference results to approved channels.
- Data Scientist / ML Engineer — may invoke all tiers for approved experiments; write access to the model registry sandbox.
- Security Manager — may invoke Tiers 1 to 3 models; may approve temporary elevation to Tier 4 for direct reports.
- CISO / Executive — full Tier 4 access; may grant emergency break-glass authorisation.

RBAC scales well because when a person changes role their access changes automatically without per-user edits. It also simplifies audits: reviewers assess roles rather than thousands of individual user-permission combinations.

4. Attribute-Based and Contextual Controls

Where RBAC is too coarse, attribute-based access control (ABAC) adds conditional logic. An ABAC policy might state: Grant access to the threat-intelligence model only if the subject holds the ThreatIntel role AND is connecting from a managed device AND the request originates within business hours (06:00-22:00 UTC). Three attributes must all evaluate to true simultaneously — analogous to a bank vault requiring two keys plus a combination. ABAC is most appropriate for Tier 3 and Tier 4 models where the cost of inappropriate access justifies the additional complexity.

Context matters: The same user credential that legitimately accesses a model from a managed endpoint during business hours may be denied when the request arrives at 03:00 from an unmanaged device in an unexpected geography — even if the password and MFA token are both correct.

5. Just-In-Time and Temporary Access

Persistent access is a liability. Just-in-time (JIT) provisioning grants access at the moment it is needed and expires it automatically after a defined window. Practical patterns include:

- Shift-based JIT — an analyst requests access at the start of a shift; access is granted for 12 hours and expires at shift end.
- Project-scoped access — a contractor working a 30-day engagement receives a 30-day credential that is not renewable without re-approval.
- Incident-triggered elevation — during an active incident, a manager grants emergency Tier 4 access for 48 hours via a break-glass workflow; all actions are logged with the incident ticket number.

JIT eliminates the forgotten access problem — the contractor who finished six months ago but whose credentials were never revoked. Automated expiry is a simpler and more reliable control than relying on manual offboarding.

Real-World Incident — Capital One Data Breach (2019): A misconfigured WAF combined with an over-privileged IAM role allowed an attacker to exfiltrate over 100 million customer records from AWS S3. The IAM role had persistent, broad permissions far beyond what the compute instance required. JIT provisioning and strict least-privilege scoping on cloud roles would have limited the attacker's ability to pivot to sensitive storage buckets — a lesson directly applicable to AI inference infrastructure permissions.

6. Authentication Requirements for Model APIs

Every access path to a model — whether through a web UI, REST API, gRPC endpoint, or internal microservice — must enforce strong authentication. Minimum requirements for enterprise AI systems:

- Multi-factor authentication (MFA) for all human users — password plus TOTP, FIDO2 security key, or push notification.
- Short-lived API tokens (OAuth 2.0 client credentials, JWTs with a maximum TTL of one hour) for service accounts and automated pipelines.
- Integration with the corporate identity provider (IdP) — when a user is offboarded in Active Directory or Okta, all downstream model access is automatically revoked.
- Mutual TLS (mTLS) for service-to-service inference calls in zero-trust network architectures.
- Prohibition on static shared API keys — each consumer gets a unique, rotatable credential scoped to specific models.

7. Per-Model API Keys and Credential Scoping

Issuing a single master key that grants access to all models is a critical design flaw. Credential scoping restricts each key to the minimum set of models the consuming application requires. If a web application only calls the phishing-detection model, its API key should be scoped to that single model. A compromised key then yields access to only one model rather than the entire portfolio. This is the API-key equivalent of separate physical keys for house, car, and office — minor operational overhead, major risk reduction.

8. Request and Approval Workflow for Elevated Access

For Tier 3 and Tier 4 models, an automated self-service request-and-approval workflow reduces friction while maintaining control:

- Requester submits a form stating: which model, business justification, required duration, and data classification of queries.
- Immediate manager receives an approval task; approval is time-boxed (e.g. must respond within 4 hours).
- If approved, the IAM system provisions a scoped, time-limited credential and notifies the requester.
- Access expires at the agreed end date; an optional renewal request triggers the same workflow.
- All approvals, denials, and expirations are written to an immutable audit log.

This creates a documented chain of accountability and satisfies compliance frameworks (SOC 2, ISO 27001, NIST AI RMF) that require evidence of access governance.

9. Logging, Monitoring, and Anomaly Detection

Access controls are only as effective as the visibility layer that detects when they are being circumvented or abused. Every inference request should generate a structured log record containing: timestamp,

requesting identity, model ID and version, input token count, output token count, latency, source IP, and authorisation outcome (permit or deny). Aggregate these logs in a SIEM and define detection rules:

Anomaly Pattern	Possible Cause	Response
Query volume > 10x 7-day baseline	Credential compromise or scraping attack	Auto-suspend credential; alert security team
Access at unusual hours from new geography	Account takeover	Require step-up MFA; flag for investigation
Denied-then-permitted pattern within 60 s	Privilege escalation attempt or misconfiguration	Review approval audit trail
Query content similarity spike (near-duplicate prompts)	Model extraction or adversarial probing	Rate-limit; notify ML security team

10. Periodic Access Review (Recertification)

Access rights drift over time. People change roles, finish projects, and leave organisations. A quarterly access recertification cycle prevents accumulation of stale permissions:

- Generate a report of all identities with access to each model, grouped by tier.
- Route each access record to the identity's current manager for a confirm or revoke decision.
- Auto-revoke any record where no response is received within the review window (typically 14 days).
- Track recertification completion rates as a security KPI; report to the CISO.

Analogy: quarterly recertification is the security equivalent of changing the locks whenever someone leaves your building — you can rely on physical barriers only if you know who holds active keys.

Key Terms Glossary

Term	Definition
Least Privilege	Principle that every identity should be granted only the minimum permissions required to perform its defined function.
RBAC (Role-Based Access Control)	Access control model where permissions are assigned to roles and users are assigned to roles, not given permissions directly.
ABAC (Attribute-Based Access Control)	Access control model where authorisation decisions evaluate multiple attributes (role, device state, time, location) against a policy.
Just-In-Time (JIT) Access	Provisioning pattern where access is granted at the moment of need and automatically revoked after a predefined window.
Break-Glass Access	Emergency procedure allowing an authorised escalator to grant time-limited elevated permissions, fully logged and post-incident reviewed.
Credential Scoping	Restricting an API key or service account token to a specific set of resources (models, endpoints) rather than granting broad access.
Model Registry	A centralised inventory of AI models, their versions, sensitivity classifications, and approved consumers.

Access Recertification	Periodic review process where current managers confirm or revoke existing access grants for their direct reports.
mTLS (Mutual TLS)	TLS variant where both client and server present certificates to each other, enabling bidirectional authentication for service-to-service calls.
Inference Endpoint	The API surface through which client applications submit inputs to an AI model and receive outputs.

Quick Revision Checklist

- Model access controls govern who can invoke which models under what conditions — they are distinct from data access controls.
- A four-tier classification system (Public, Internal, Restricted, Confidential) provides a practical sensitivity framework.
- RBAC assigns permissions to job roles; ABAC adds contextual conditions (time, device, location) for higher-sensitivity models.
- Just-in-time provisioning and automatic expiry eliminate stale credentials — a leading cause of AI infrastructure breaches.
- Every model should have its own scoped API credential; shared master keys are a critical anti-pattern.
- Multi-factor authentication and IdP integration are mandatory; static passwords alone are insufficient.
- All inference requests generate structured audit logs reviewed by SIEM anomaly detection rules.
- Quarterly access recertification ensures permissions stay aligned with current job functions.
- Break-glass procedures balance security with incident response agility — always log and post-review.
- The Capital One 2019 breach illustrates the direct cost of over-privileged persistent IAM roles.

10 Exam-Based MCQs — Model Access Controls

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* A financial services firm has deployed 14 AI models over the past two years with no unified access governance. The CISO has tasked a security architect with building a model access control programme from scratch. The architect has two weeks before the board review. Which FIRST action should the security architect take?

- A) Implement MFA on all model inference endpoints immediately.
- B) Build a model inventory with sensitivity classifications before enforcing access policies.
- C) Deploy a SIEM to monitor inference logs for anomalies.
- D) Configure per-model API keys for all existing consumers.

Answer: B **Explanation:** B is correct because you cannot enforce appropriate access controls without first knowing what models exist and how sensitive they are — classification drives all downstream policy

decisions. A is a strong control but applying MFA uniformly before understanding model sensitivity leads to over-engineering on low-risk models and potential gaps on high-risk ones. C is a valuable monitoring layer but is not the foundation of access governance. D requires a model inventory to define scope — you cannot create meaningfully scoped keys without knowing which models exist.

Q2. Scenario: A threat intelligence team of twelve analysts uses a Tier 4 predictive model that incorporates unpublished zero-day intelligence. The team works across three time zones and occasionally accesses the model from personal laptops. Three senior analysts regularly access the model at weekends. What is the MOST appropriate access control approach for the high-sensitivity model?

- A) RBAC: grant access to all members of the Threat Intelligence team role.
- B) ABAC: grant access to Threat Intelligence team members connecting from a managed device during business hours with MFA.
- C) Grant persistent access to the three senior analysts and review quarterly.
- D) Require a manager approval email for every individual query.

Answer: B Explanation: B is correct because ABAC combines role (Threat Intelligence membership), device posture (managed endpoint), and temporal context (business hours) — three independent attributes that together establish high assurance for a Tier 4 model. A (RBAC alone) is too coarse — it does not account for device state or unusual access hours that may indicate credential compromise. C creates persistent access that accumulates over time and is not automatically revoked when analysts change roles. D is impractical operationally and would create bottlenecks without adding meaningful security over a well-configured ABAC policy.

Q3. Scenario: A SOC platform and a SIEM integration both use the same static API key to access a threat-classification model. A red team exercise reveals the key is stored in plaintext in both applications' configuration files. The key has not been rotated in 14 months. Which control BEST addresses the identified risk?

- A) Implement ABAC policies restricting access to office IP ranges.
- B) Replace the shared API key with per-application scoped credentials with automated rotation.
- C) Add MFA to the model's web UI.
- D) Enable quarterly access recertification for all API consumers.

Answer: B Explanation: B is correct because it directly addresses credential sharing (per-application keys) and the persistence risk (automated rotation). If one application's key is compromised, only that application's model access is at risk. A restricts network location but does not address the shared credential problem — an attacker with the key can use it from an authorised IP. C protects interactive web access but has no effect on API calls using the shared key. D is a governance control that detects stale access quarterly but does not prevent real-time misuse of an already-compromised shared credential.

Q4. Which access provisioning pattern BEST eliminates the risk of stale contractor credentials?

- A) Require contractors to submit a manual offboarding request when their engagement ends.
- B) Use just-in-time provisioning with credentials that expire at the contract end date.

- C) Add all contractors to a Restricted group and review membership monthly.
- D) Issue contractors temporary passwords that they must change on first login.

Answer: B **Explanation:** B is correct because JIT provisioning ties the credential lifetime to the business need (contract duration). The credential expires automatically — no human action is required and no forgotten offboarding scenario is possible. A relies on humans remembering to act and is therefore unreliable. C requires monthly review but access persists between reviews; a contractor whose engagement ended the day after a review retains access for up to a month. D addresses initial password hygiene but does not limit the credential lifetime — the changed password persists indefinitely.

Q5. Which monitoring alert is MOST indicative of a model extraction attack?

- A) A single user's query volume exceeds their 30-day average by 2x.
- B) A service account submits thousands of semantically similar prompts across a 6-hour window.
- C) An analyst accesses a model outside normal business hours on a weekend.
- D) A new user completes MFA enrollment and immediately queries a Tier 2 model.

Answer: B **Explanation:** B is correct. Model extraction attacks systematically query a model to reconstruct its behaviour — this produces high-volume, near-duplicate or systematically varied prompts from a single identity over a short window. A 2x spike from a single user (option A) could be routine workload variation. Weekend access (option C) may be legitimate for on-call staff and requires investigation but is not a strong extraction signal on its own. A new user completing MFA and then querying a model they are authorised to use (option D) is expected behaviour.

Q6. What does 'credential scoping' mean in the context of model access controls?

- A) Requiring users to scope their queries to a maximum token limit per request.
- B) Restricting each API key to a defined set of models rather than granting access to all models.
- C) Classifying credentials by sensitivity tier to match the model they access.
- D) Rotating API keys on a schedule determined by the model's sensitivity classification.

Answer: B **Explanation:** B is correct. Credential scoping means the API key issued to an application is authorised to call only the specific models that application needs — not every model in the portfolio. This limits blast radius on compromise. A describes input or output token limits, which is a quota control, not credential scoping. C describes credential classification, not scoping. D describes key rotation policy, a separate control from scoping.

Q7. Which authentication approach provides the STRONGEST assurance for human users accessing a Tier 4 model?

- A) Username and password with a minimum length of 16 characters.
- B) Static API key with IP allowlisting.
- C) FIDO2 hardware security key plus IdP-managed session with a 1-hour maximum lifetime.
- D) TOTP-based MFA with a 30-day session cookie.

Answer: C **Explanation:** C is correct. A FIDO2 hardware security key provides phishing-resistant MFA (the

private key never leaves the hardware token), and an IdP-managed session with a short lifetime limits the window of exposure if a session is hijacked. A is a single factor — a strong password alone is insufficient for high-sensitivity access. B is a service-account pattern inappropriate for human users and relies on network-layer controls rather than strong authentication. D uses TOTP (software-based MFA) rather than a phishing-resistant hardware token, and a 30-day session cookie is far too long for Tier 4 access.

Q8. Which statement about access recertification is CORRECT?

- A) Recertification is only required for external users and contractors, not employees.
- B) Auto-revoking access when a manager does not respond within the review window is a security risk.
- C) Quarterly recertification ensures that access rights stay aligned with current job functions and removes stale grants.
- D) Recertification replaces the need for JIT access because it reviews all permissions regularly.

Answer: C **Explanation:** C is correct. Periodic recertification is the lifecycle control for managing permissions — it surfaces grants that persist beyond their legitimate need and provides a documented governance trail for auditors. A is incorrect: employees change roles and take on new responsibilities; their access must also be reviewed. B is incorrect: auto-revocation on non-response is a deliberate safe-fail design — silence is treated as inability to confirm continued need, so access is removed rather than retained. D is incorrect: recertification and JIT are complementary, not substitutes.

Q9. Under which circumstance is break-glass access MOST appropriate?

- A) A data scientist wants to experiment with a Tier 4 model before submitting a formal access request.
- B) An analyst needs Tier 4 model access to respond to an active ransomware incident at 02:00.
- C) A manager wants to demonstrate a restricted model to a potential enterprise customer.
- D) A developer needs to test API integration against a production Tier 3 model.

Answer: B **Explanation:** B is correct. Break-glass procedures are designed for genuine emergencies where the normal approval workflow would cause unacceptable delay. An active ransomware incident at 02:00 meets this threshold. A is discretionary experimentation that should follow the standard request-approval workflow. C is a planned business development activity that can be arranged in advance. D is a development task that should use a sandbox environment with a non-production model — using production break-glass access for testing misuses the control and pollutes the audit log.

Q10. Which combination of controls MOST directly addresses the risk illustrated by the Capital One 2019 breach as it applies to AI model infrastructure?

- A) Encrypting all model weights at rest and in transit.
- B) Deploying a WAF in front of all model inference endpoints.
- C) Applying least-privilege IAM policies to inference service roles and using JIT access for elevated operations.

D) Enabling CloudTrail logging for all model API calls.

Answer: C **Explanation:** C is correct. The Capital One breach was fundamentally an over-privileged persistent IAM role problem. Least-privilege IAM scoping and JIT access for elevated operations directly address both dimensions of that root cause. A (encryption) protects data confidentiality but would not have prevented the breach, which exploited authorisation. B (WAF) was the misconfigured component in the Capital One breach — adding one does not compensate for privilege misconfiguration behind it. D (logging) is a detective control that would help identify the breach faster but does not prevent the over-privilege that enabled it.